Module 02: Reconnaissance

Open Source Intelligence (OSINT)

Project Athena

What is OSINT?

Open Source Intelligence

Turning **publicly available** data into actionable intelligence.

- No hacking, no unauthorized access
- Raw data → analysis → intelligence
- Used for pentests, threat intel, incident response


Always has been
Wait, it's
all public data?
Memegen.link

Four Flavours

1. People

- Social media, GitHub, resumes
- Breach notification services (Have I Been Pwned)
- Photo metadata (EXIF)
- **Why it matters:** this is what phishing is built on


Your LinkedIn profile
A phishing email template
Corporate needs you to find the differences between this picture and this picture.
They're the same picture
They're the same picture.
Memegen.link

2. Organizations

- Website, press releases, job postings
- LinkedIn: who works there, what they do
- **Yields:** email format, tech stack, org chart


Marketing team
Job posting listing the entire tech stack
Is this a press release?
Memegen.link

3. Technical

- WHOIS, DNS, TLS certificates
- Shodan, Censys
- Wayback Machine, public code repos
- **Yields:** IP ranges, subdomains, exposed services

4. Geospatial

- Maps, street view, satellite imagery
- Geotagged posts and photos
- **Yields:** facility layout, entrances, working hours

Tools

Technical OSINT in Four Commands

```
whois example.com
dig example.com ANY
amass enum -d example.com
# subdomains via certificate transparency:
# https://crt.sh/?q=%.example.com
```

Usernames and Emails

```
theHarvester -d example.com -b google,linkedin
sherlock username123      # same handle on other platforms?
```

Frameworks

- **Maltego** – visual link analysis
- **Recon-ng** – modular, database-backed
- **SpiderFoot** – automated, 200+ modules
- **osintframework.com** – the map of everything

Images

```
exiftool photo.jpg   # GPS, camera, timestamp
```

Reverse image search: Google, TinEye, Yandex.

Workflow

Company Recon in Five Steps

1. Domains and subdomains (`whois`, `amass`, `crt.sh`)
2. Employees and email format (LinkedIn, theHarvester)
3. Tech stack (job postings, Wappalyzer)
4. Exposed services (Shodan, Censys)
5. Draw the graph (Maltego)

Rules

Public Is Not the Same as Fair Game

- Terms of service, GDPR, anti-scraping laws still apply
- Purpose matters: research vs. harassment
- Store what you collect securely

Golden rule

Would you be fine if someone did this to you?

Finding is recon. Accessing is intrusion.

Defense

Protect Yourself

- Lock down social media privacy
- Strip EXIF before posting
- Separate handles and emails per purpose
- Do a self-OSINT audit once in a while

Protect the Organization

- Review job postings for over-sharing
- WHOIS privacy
- Monitor for leaked credentials
- Quarterly self-OSINT audit

Exercise: Self-OSINT

1. Search your own name in quotes
2. Check Have I Been Pwned
3. Reverse-search your profile picture
4. Write down what surprised you

Resources

- osintframework.com
- inteltechniques.com
- “We Are Bellingcat” by Eliot Higgins
- Trace Labs OSINT CTF

Module 02: Reconnaissance

Open Source Intelligence (OSINT)

Project Athena